



UnionPay Integrated Circuit Card Specifications

— Product Specifications

Part IV Digital Certificate Specification



Version 2014

THIS PAGE IS INTENTIONALLY LEFT BLANK.

Table of Contents

1	Application Scope	1
2	Normative References	2
3	Terms and Definitions	3
3.1	Block	3
3.2	Interface Device	3
3.3	Terminal	3
3.4	Command	3
3.5	Concatenation.....	3
3.6	Contact	3
3.7	Response	3
3.8	Prologue Field	3
3.9	Epilogue Field	4
3.10	Function.....	4
3.11	Guard time.....	4
3.12	Hash Function	4
3.13	Hash Result	4
3.14	Inactive	4
3.15	Integrated Circuit (IC)	4
3.16	Integrated Circuit(s) Card	4
3.17	Message.....	5
3.18	Message Authentication Code.....	5
3.19	Nibble	5
3.20	Plain Text.....	5
3.21	Cipher Text.....	5
3.22	Key	5
3.23	Digital Signature	5
3.24	Encryption Algorithm.....	5

3.25	Certification Authority	5
3.26	Symmetric Encryption Technique	5
3.27	Asymmetric Encryption Technique.....	5
3.28	Private Key	6
3.29	Public Key	6
3.30	Public Key Certification.....	6
3.31	Secret Key	6
3.32	Data Integrity	6
4	Symbols and Acronym.....	7
5	Electromechanical Property, Logic Interface and Transport Protocol	14
6	Digital Certificate Application Procedures	15
6.1	Digital Certificate Application Realization Structure	15
6.2	Digital Certificate Application Flow - Certificate apply/Update	15
6.3	Digital Certificate Application Procedures-Signature and Authentication	17
7	Security Mechanism	20
7.1	Basic Security Requirement	20
7.1.1	<i>Coexisting Application</i>	<i>20</i>
7.1.2	<i>Key Independence.....</i>	<i>20</i>
7.1.3	<i>Storage of Keys and Personal Identification Number (PIN).....</i>	<i>20</i>
7.1.4	<i>Personal Identification Number (PIN) Authentication</i>	<i>20</i>
7.2	Secure Message Transport.....	20
7.2.1	<i>Secure Message Transport Format</i>	<i>20</i>
7.2.2	<i>Message Integrity and Authentication.....</i>	<i>21</i>
7.2.3	<i>Data Reliability</i>	<i>23</i>
7.2.4	<i>Cases for Secure Message Transport Command.....</i>	<i>27</i>
7.3	Approved Encryption Algorithm.....	28
7.3.1	<i>Symmetric Algorithm (DES).....</i>	<i>28</i>
7.3.2	<i>Asymmetric Algorithm (RSA)</i>	<i>28</i>
7.3.3	<i>Secure Hash Algorithm (SHA-1)</i>	<i>30</i>

7.3.4	<i>Symmetric Algorithm (SM1)</i>	30
7.3.5	<i>Asymmetric Algorithm (SM2)</i>	30
7.3.6	<i>Digest Algorithm (SM3)</i>	30
8	Command	31
8.1	C-APDU Format	31
8.2	R-APDU Format	31
8.3	Create File	32
8.3.1	<i>Definition and Scope</i>	32
8.3.2	<i>Command Message</i>	33
8.3.3	<i>Command Message Data Field</i>	33
8.3.4	<i>Response Message Data Field</i>	34
8.3.5	<i>Response Message Status Code</i>	34
8.4	Compute Digital Signature	34
8.4.1	<i>Definition and Scope</i>	34
8.4.2	<i>Command Message</i>	34
8.4.3	<i>Command Message Data Field</i>	35
8.4.4	<i>Response Message Data Field</i>	35
8.4.5	<i>Response Message Status Code</i>	35
8.5	Compute HASH (HASH Computation)	35
8.5.1	<i>Definition and Scope</i>	35
8.5.2	<i>Command Message</i>	36
8.5.3	<i>Command Message Data Field</i>	36
8.5.4	<i>Response Message Data Field</i>	37
8.5.5	<i>Response Message Status Code</i>	37
8.6	Encipher/Decipher	37
8.6.1	<i>Definition and Scope</i>	37
8.6.2	<i>Command Message</i>	38
8.6.3	<i>Command Message Data Field</i>	38
8.6.4	<i>Response Message Data Field</i>	38

8.6.5	Response Message Status Code.....	38
8.7	Verify PIN (PIN Verification)	39
8.7.1	Definition and Scope	39
8.7.2	Command Message.....	39
8.7.3	Command Message Data Field	39
8.7.4	Response Message Data Field.....	39
8.7.5	Response Message Status Code.....	39
8.8	Get Challenge (Get Random Number).....	40
8.8.1	Definition and Scope	40
8.8.2	Command Message.....	40
8.8.3	Command Message Data Field	40
8.8.4	Response Message Data Field	41
8.8.5	Response Message Status Code.....	41
8.9	Generate Asymmetric Key (Generate Public and Private Key Pair)	41
8.9.1	Definition and Scope	41
8.9.2	Command Message.....	41
8.9.3	Command Message Data Field	42
8.9.4	Response Message Data Field	42
8.9.5	Response Message Status Code.....	42
8.10	Manage Security Environment (Security Environment Management).....	43
8.10.1	Definition and Scope	43
8.10.2	Command Message.....	43
8.10.3	Command Message Data Field	44
8.10.4	Response Message Data Field	45
8.10.5	Response Message Status Code.....	45
8.11	Perform Security Operation (Security Operation)	46
8.12	Read Binary (Read Binary File).....	46
8.12.1	Definition and Scope	46
8.12.2	Command Message.....	46

8.12.3	Command Message Data Field	47
8.12.4	Response Message Data Field	47
8.12.5	Response Message Status Code.....	47
8.13	Read Record (Read Record File)	47
8.13.1	Definition and Scope	47
8.13.2	Command Message.....	47
8.13.3	Command Message Data Field	48
8.13.4	Response Message Data Field	48
8.13.5	Response Message Status Code.....	48
8.14	Update Binary (Update Binary File).....	49
8.14.1	Definition and Scope	49
8.14.2	Command Message.....	49
8.14.3	Command Message Data Field	49
8.14.4	Response Message Data Field	49
8.14.5	Response Message Status Code.....	49
8.15	Update Record (Update Record File).....	50
8.15.1	Definition and Scope	50
8.15.2	Command Message.....	50
8.15.3	Command Message Data Field	51
8.15.4	Response Message Data Field	51
8.15.5	Response Message Status Code.....	51
8.16	Verify Signature (Signature Verification).....	51
8.16.1	Definition and Scope	51
8.16.2	Command Message.....	52
8.16.3	Command Message Data Field	52
8.16.4	Response Message Data Field	52
8.16.5	Response Message Status Code.....	52
8.17	Write PIN (Load or Update PIN)	53
8.17.1	Definition and Scope	53

8.17.2	<i>Command Message</i>	53
8.17.3	<i>Command Message Data Field</i>	53
8.17.4	<i>Response Message Data Field</i>	54
8.17.5	<i>Response Message Status Code</i>	54
Appendix A	Basic Data File (EF)	56
Appendix B	Loading of Asymmetric Key	61
B.1	Use Update Record Command To Load Private Key	61
B.2	Use Update Record Command To Load Public Key.....	61
B.3	Use Generate Asymmetric Key Command to Load (Generate) Public Key and Private Key Simultaneously	62
Appendix C	Card Reader Terminal Configuration Recommendation	63

1 Application Scope

This book applies to all UPI participants.

2 Normative References

The clauses in the following documents constitute an integral part of these Standards through reference herein. None of the revisions (excluding contents of the corrigendum) or revised versions of dated reference documents are applicable to these Standards. For non-dated references, their latest editions are applicable to these Standards.

ISO 639:1988 *Code for the Representation of Names of Languages*

ISO 8731-1:1987 *Banking — Approved Algorithms for Message Authentication— Part 1: DEA*

ISO 8732:1987 *Encryption Algorithm of 64 -bit Block Encryption Algorithm for Information Processing*

ISO 8583:1993 *Bankcard Originated Messages--Interchange Message Specifications--Content for Financial Transactions*

IEC 512-2:1979 *Specifications for Electromechanical Components for Electromechanical Equipment - Part 2: Contact resistance tests, insulation tests and voltage stress tests*

ISO/IEC 7816-3—1992 *Identification Cards - Integrated Circuit(s) Cards with Contacts - Part 3: Electronic signals and transmission protocols AMENDMENT 1: Protocol type T=1, asynchronous half duplex block transmission protocol*

ISO/IEC 7816-3—1994 *Identification Cards - Integrated Circuit(s) Cards with Contacts - Part 3: Electronic signals and transmission protocols AMENDMENT 2: protocol type selection (draft of international standards)*

ISO/IEC 9796-2 *Security Techniques -- Digital Signature Schemes Giving Message Recovery -- Part 2: Hash factorization based mechanisms*

ISO/IEC 9797:1993 *Information Technology - Security Techniques - Data integrity mechanisms using an encryption check function employing a block cipher algorithm*

ISO/IEC 10116:1993 *Information Technology - Security Techniques - Hash Function Part 3: Special hash function*

ISO/IEC 10373:1993 *Identification Cards - Test Methods*

FIPS Pub 180-1:1995 *Secure Hash Standard*

EMV Payment System Integrated Circuit Card Specifications: 2004, Volume 1 - 4

3 Terms and Definitions

The following terms and definitions are applicable to this part:

3.1 Block

A set of characters comprising two or three fields (prologue field, information field, and epilogue field).

3.2 Interface Device

That part of a terminal into which the IC card is inserted, including such mechanical and electrical devices that may be considered part of it.

3.3 Terminal

The device installed at the point of transaction for connection with IC card to perform a digital certificate based transaction. It incorporates the interface device and may also include other components and interfaces such as host communications interface.

3.4 Command

A message sent by the terminal to the IC card that initiates an action and solicits a response from the IC card.

3.5 Concatenation

Two elements are concatenated by appending the bytes from the second element to the end of the first. Bytes from each element are represented in the resulting string in the same sequence in which they were presented to the terminal by the IC card, that is, most significant byte first. Within each byte bits are ordered from most significant bit to least significant. A list of elements or objects may be concatenated by concatenating the first pair to form a new element, using that as the first element to concatenate with the next in the list, and so on.

3.6 Contact

A conducting element ensuring galvanic continuity between integrated circuit(s) and external interfacing equipment.

3.7 Response

A message returned by the IC card to the terminal after the processing of a command message received by the IC card.

3.8 Prologue Field

The first part of a block that consists of node address (AD), protocol control byte (PCB) and length (LEN).

3.9 Epilogue Field

The last part of a block that contains the error detection code (EDC).

3.10 Function

A process accomplished by one or more commands and resultant actions that are used to perform all or part of a transaction.

3.11 Guard time

The minimum time between the trailing edge of the parity bit of a character and the leading edge of the start bit of the following character sent in the same direction.

3.12 Hash Function

A function that maps strings of bits to fixed-length strings of bits, satisfying the following two properties:

- It is computationally infeasible to find for a given output an input which maps to this output;
- It is computationally infeasible to find for a given input a second input that maps to the same output.

Additionally, if the hash function is required to be collision-resistant, it must also satisfy the following property:

It is computationally infeasible to find any two distinct inputs that map to the same output.

3.13 Hash Result

The string of bits that is the output of a hash function.

3.14 Inactive

The supply voltage (VCC) and other signals to the IC card are in the inactive state when they are at a potential of 0.4 V or less with respect to ground (GND).

3.15 Integrated Circuit (IC)

Electronic component(s) designed to perform processing and/or memory functions.

3.16 Integrated Circuit(s) Card

ID—1 type card into which one or more integrated circuits are inserted (as described in ISO7810, ISO7811 Part 1- 5, ISO7812 and ISO7813).

3.17 Message

A string of bytes sent by the terminal to the card or vice versa, excluding transmission-control characters.

3.18 Message Authentication Code

Code generated after operation of transaction data and relevant parameters, which is mainly use for verification of message integrity.

3.19 Nibble

The four most significant or least significant bits of a byte.

3.20 Plain Text

Unencrypted information.

3.21 Cipher Text

Incomprehensible words or signals generated by cryptosystem.

3.22 Key

Symbol sequence controlling encryption conversion operation.

3.23 Digital Signature

A kind of asymmetric encryption data conversion which allows the recipient to verify the originality and integrity of data, protecting data sent and received from being forged by a third party; for the sender, it could also be used to prevent forgery by the recipient.

3.24 Encryption Algorithm

An algorithm that transforms data in order to hide or reveal its information content.

3.25 Certification Authority

A third party organization that provides reliable verification to the owner by using public key and other relevant data.

3.26 Symmetric Encryption Technique

An encryption technique that uses the same secret key for both the sender's and recipient's transformation. Without knowledge of the secret key, it is computationally infeasible to compute either the sender's or the recipient's transformation.

3.27 Asymmetric Encryption Technique

An encryption technique that uses two related transformations, a public transformation (defined by the public key) and a private transformation (defined by the private key). The two transformations have the property that, given the public

transformation, it is computationally infeasible to derive the private transformation.

3.28 Private Key

The key of an entity's asymmetric key pair that should only be used by that entity. In the case of a digital signature scheme, the private key defines the signature function.

3.29 Public Key

The key of an entity's asymmetric key pair that can be made public. In the case of a digital signature scheme, the public key defines the verification function.

3.30 Public Key Certification

The public key information of an entity signed by the certification authority and thereby rendered non-forgable.

3.31 Secret Key

A key used with symmetric encryption techniques and usable only by a set of specified entities.

3.32 Data Integrity

The property that data has not been altered or destroyed in an unauthorized manner.

4 Symbols and Acronym

The following symbols and acronyms are applicable for this part:

ADF	Application Definition File
AID	Application Identifier
An	Alphanumeric
Ans	Alphanumeric Special
APDU	Application Protocol Data Unit
ASN	Abstract Syntax Notation
ATR	Answer to Reset
B	Binary
BER	Basic Encoding Rules
BGT	Block Guard Time
BWI	Block Waiting Time Integer
BWT	Block Waiting Time
C-APDU	Command APDU
CBC	Cipher Block Chaining
CIN	Input Capacitance
CLA	Class Byte of the Command Message
cn	Compressed numeric
C-TPDU	Command TPDU
DAD	Destination Node Address

DDF	Directory Definition File
DEA	Data Encryption Algorithm; in this part, DEA algorithm refers to DES algorithm.
DES	Data Encryption Standard
DF	Dedicated File
DIR	Directory
EDC	Error Detection Code
EF	Elementary File
FCI	File Control Information
F	Frequency
FIPS	Federal Information Processing Standard
GND	Ground
Hex	Hexadecimal
HHMM	Hours, Minutes
HHMMSS	Hours, Minutes, Seconds
I-block	Information Block
IC	Integrated Circuit
ICC	Integrated Circuit Card
IEC	International Electrotechnical Commission
IFD	Interface Device
IFS	Information Field Size

IFSC	Information Field Size for the ICC
IFSD	Information Field Size for the Terminal
INF	Information Field
INS	Instruction Byte of Command Message
I/O	Input/Output
ISO	International Organization for Standardization
KM	Master Key
KS	Session Key
Lc	Exact Length of Data Sent by the TAL IN A Case 3 or 4 Command
Lcm	Least Common Multiple
Le	Maximum Expected Length of Response Data
Licc	Exact Length of Data Available Returned in Response to the Case 2 or 4 Command Received by the ICC
LEN	Length
Lr	Length of Response Data Field
LRC	Longitudinal Redundancy Check
M	Mandatory
MAC	Message Authentication Code.
MF	Mater File
N	Numeric
NAD	Node Address

NAK	Negative Acknowledgment
NCA	Length of the Certification Authority Public Key Modulus
NI	Length of the Issuer Public Key Modulus
NIC	Length of the IC Card Public Key Modulus
O	Optional
P1	Parameter 1
P2	Parameter 2
P3	Parameter 3
PCA	Certification Authority Public Key
PCB	Protocol Control Byte
PI	Issuer Public Key
PIC	ICC Public Key
PIN	Personal Identification Number
PIX	Proprietary Application Identifier Extension
PSA	Payment System Application
PSE	Payment System Environment
PTS	Protocol Type Selection
R-APDU	Response APDU
RFU	Reserved for Future Use
RID	Registered Application Provider Identifier
RSA	Rivest, Shamir, Adleman

RST	Reset
R-TPDU	Response TPDU
SAD	Source Node Address
SAM	Secure Access Module
SCA	Certification Authority Private Key
SI	Issuer Private Key
SIC	ICC Private Key
SFI	Short File Identifier
SHA	Secure Hash Algorithm
SM1	Domestic Symmetric Algorithm
SM2	Domestic Asymmetric Algorithm
SM3	Domestic Digest Algorithm
SW1	Status Word One
SW2	Status Word Two
TCK	Check Character
TLV	Tag, Length, Value
TPDU	Transport Protocol Data Unit
TTL	Terminal Transport Layer
TVR	Terminal Verification Results
VCC	Voltage Measured on VCC Contact
WI	Waiting Time Integer

CCYYMMDD	Year, Month, Day
'0'~'9' 'A'~'F'	hexadecimal digit
[]	Optional
A:=B	A is assigned with the value of B
A=B	A equals to B
$A \equiv B \pmod n$	Differential mode of integer A and B, that is, there is an integer d making $(A-B)=dn$
$A \bmod n$	A mod n
Abs(n)	Absolute value of n
$Y:=\text{ALG}(K)[X]$	Using the secret key K to encrypt 64-bit data block X through 64-bit block encryption method.
$X:=\text{ALG}^{-1}(K)[Y]$	Using the secret key K to decrypt 64-bit data block Y through 64-bit block encryption method.
$Y:=\text{Sign}(S_K)[X]$	Using the private key S_K to sign data block X through asymmetric reversible algorithm.
$X=\text{Recover}(P_K)[Y]$	Using the public key S_K to recover electronic signature data block Y through asymmetric reversible algorithm.
$C:=(A\ B)$	Concatenate m-bit block B to n-bit block A, defined as: $C=2^m A + B$
$H:=\text{Hash}[\text{MSG}]$	Using 80-bit hash function to perform hash operation on message MSG
Lcm(a,b)	Least common multiple of two integers a and b
	Bit length of integer N
n	Jacobi value of integer X and integer n ($n=pq$, p and q are prime numbers), defined as follows: $J:=(X(p-1)/2 \bmod p)(X(q-1)/2 \bmod q)$

$(X n)$	If $J=1$ or $j=(pq-p-q+1)$, then $(X n)=1$, otherwise $(X n)=-1$ Note: Jacobi value of integer X could also be calculated when there is no n prime number factor
Xx	Any value

5 Electromechanical Property, Logic Interface and Transport Protocol

This part refers to ISO 7816 Part 1 - 3, and is the same with EMV4.1-Integrated Circuit Card Specifications for Payment Systems Part 1, which will not be quoted here.

6 Digital Certificate Application Procedures

6.1 Digital Certificate Application Realization Structure

Overall realization of digital certificate application includes IC card end, PC end, and proprietary card reading terminal device linking the two ends, with the basic framework shown in the 0 below:

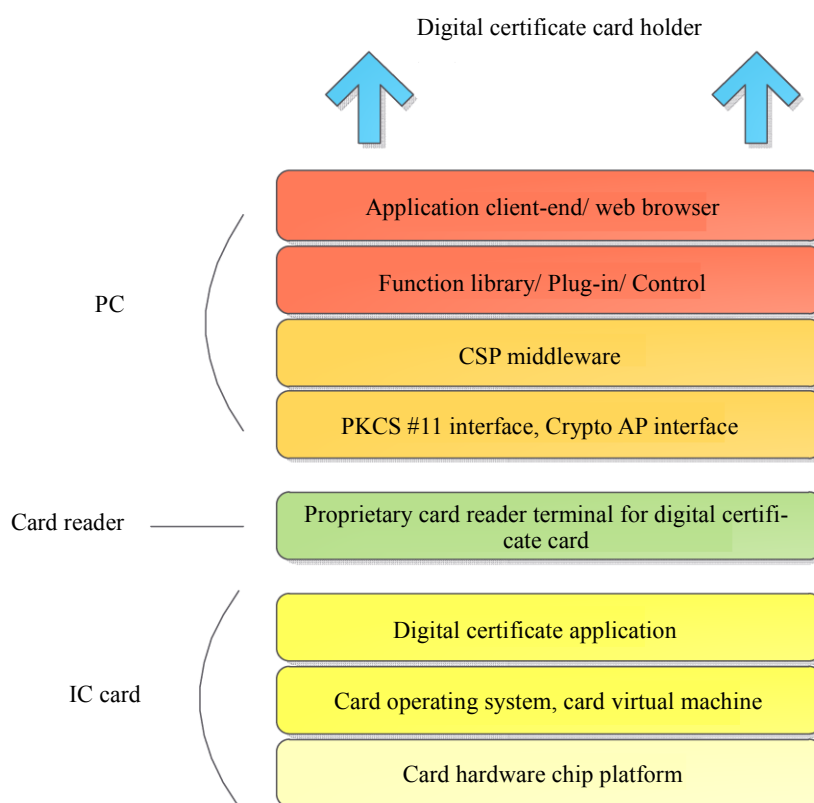


Figure 6.1 Basic framework of financial IC card digital certificate application

6.2 Digital Certificate Application Flow - Certificate apply/Update

As the core of digital certificate application, first time application and download of digital certificate corresponding with IC card, or update or extension of certificate after expiration are one of the core application links of certificate application. In general, the use frequency of this application procedure is low, which is generally operated periodically during a certain period of time.

Basic procedures of certificate application/ update are shown in the 0 below:

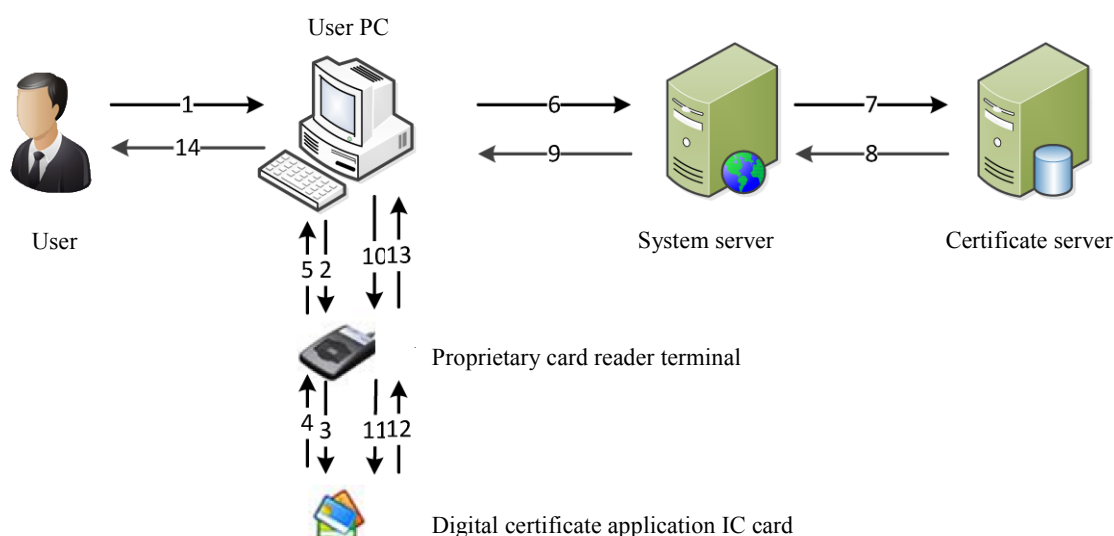


Figure 6.2 Basic Flow for Certificate Application/ Update

1. Cardholder user initiates certificate application/update transaction through relevant client-side application program or browser on PC. Certificate application is the first transaction using digital certificate application IC card for the first time, subsequent modifications to certificate shall be certificate update transactions.
2. Relevant client-side application program or browser on PC organizes and sends command generating public and private key pair to the dedicated card reader terminal, which then requires the user to confirm transaction and reminds to input digital certificate application personal identification number (PIN).
3. Card reader terminal sends command of verifying PIN to the card, which permits the receiving of command generating public and private key pair after verification. If verification is not successful, the card returns status code 63CX (error in PIN verification, X number of attempts remaining, X shall be set by the issuer). If the number of errors in verification exceeds the maximum time allowed, the card returns status code 6988 (number of errors in PIN verification exceeds limit), PIN blocked.
4. After successful verification, IC card generates public and private key pair and returns public key to designated card reader, with the private key remaining in security zone in the card. For certificate update operations, original key will be directly replaced with new key.
5. Card reader terminal forwards public key data to relevant client-side application program or browser on PC.
6. Relevant client-side application program or browser on PC organizes and requests to sign and issue message of certificate according to the format requirements specified by issuer and sends to background system server.
7. After system server completes relevant processing, it forwards the signing request to certificate server.
8. Certificate server signs the generated certificate and returns it to system server.

9. After system server completes relevant processing, it sends the generated certificate to relevant client-side application program or browser on PC according to issuer's specified format, which could select to write certificate into card and perform step 10-13.
10. Relevant client-side application program or browser on PC organizes and sends command of updating record files (the updated content being newly issued certificate) to card reader terminal.
11. Card reader terminal forwards command of updating record files to the card, updates certificate contents stored in the card and replaces the original certificate.
12. IC card returns successful update conformation.
13. Card reader terminal forwards certificate update successful confirmation to relevant client-side application program or browser on PC.
14. Relevant client-side application program or browser on PC shows relevant information to cardholder user and reminds certificate application/update successful completion.

For exceptional handling in the process of certificate application/update, refer to existing exceptional handling procedures for online banking application/update; banks may have different processing methods and no uniform requirement will be put forward here.

6.3 Digital Certificate Application Procedures-Signature and Authentication

Using private key stored in digital certificate IC card to sign sensitive data, and obtaining plain text and performing authentication after verifying signature through corresponding public key in background are one of the most frequently used application procedures in certificate application. Normally this application procedure is frequently used and is applied when identity authentication, financial payment transaction or sensitive data transmission are involved.

Card can only perform signing after completing certificate application, otherwise signing can't be completed.

Basic procedures of signing and authentication are shown in the 0below:

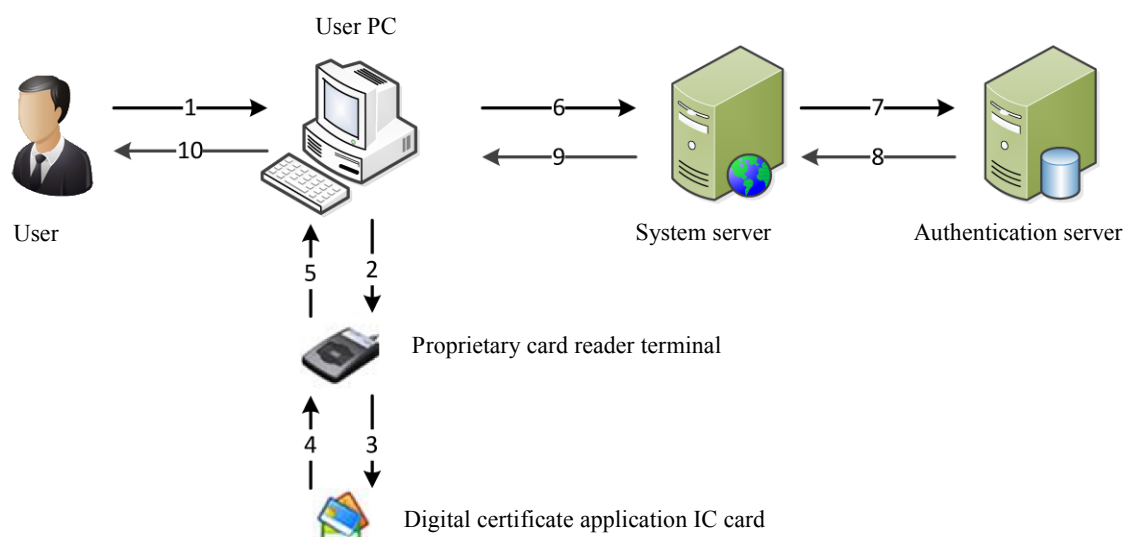


Figure 6.3 Basic Flow for Signing and Authentication

1. User uses digital certificate application IC card to perform related transactions through relevant client-side application program or browser on PC. Relevant client-side application program or browser on PC automatically decides whether to use digital certificate application IC card to perform signature protection, initiate signing and authentication transaction according to internal transaction rules.
2. Relevant client-side application program or browser on PC organizes and sends command of generating digital signature computation operation to card reader terminal, which will require user to confirm transaction. Relevant client-side application program or browser on PC will remind user to enter digital certificate application personal identification number (PIN) for first time signature authentication.
3. For first time signature authentication, card reader terminal sends command of verifying PIN to card, after successful verification, card will receive generated digital signature command. If verification is not successful, card returns status code 63CX (error in PIN verification, X number of attempts remaining, X shall be set by issuer). If number of errors in verification exceeds maximum time allowed, card returns status code 6988 (PIN try limits exceed), PIN blocked.

For security, card will not store secure state of PIN and needs to verify PIN again after recovery of power supply. With no interruption of power supply, issuer can either require PIN authentication only at the first time of performing card signature authentication or require PIN to be entered each time signature authentication is performed.
4. After successful PIN verification, card uses designated private key stored in card to perform signature computation on data entered and returns signature result to card reader terminal.
5. Card reader terminal forwards signature result to relevant client-side application program or browser on PC.
6. Relevant client-side application program or browser on PC organizes transaction message according to the format designated by issuer and sends signature result to background system server.

7. After completing relevant processing, system server forwards signature result to certificate server and requests for authentication.
8. Certificate server retrieves corresponding public key, completes authentication, returns authentication result and sends signed plain text data to system server.
9. After completing relevant processing, system server returns authentication result and returned data of transaction processing in the format designated by issuer and sends to relevant client-side application program or browser on PC.
10. Relevant client-side application program or browser on PC shows relevant information to cardholder user, reminds cardholder of successful completion of certain transaction initiated and shows relevant returned data of transaction processing.

The above procedures are consistent with the current mainstream application procedures for online banking certificate and are not mandatory, which could be adjusted according to actual situation of the system.

7 Security Mechanism

7.1 Basic Security Requirement

7.1.1 Coexisting Application

In order to independently manage security issues between different applications in one card, each application shall exist alone in the form of ADF. That is, designing a "firewall" between applications to prevent illegal cross-application access. Besides, there shall be no conflict between personalization requirement and other application rules coexisting in card in each application.

7.1.2 Key Independence

Encryption/decryption keys are only for specific function and can't be used by any other function, including keys stored in IC card and keys for generating, deriving and transmitting keys.

7.1.3 Storage of Keys and Personal Identification Number (PIN)

IC card shall be able to ensure asymmetric private key used in RSA algorithm/SM2 algorithm or symmetric encryption key used in DES algorithm/ SM1 algorithm will not be disclosed without authorization.

When personal identification number (PIN) is used, it shall be guaranteed that it is securely stored in IC card and will not be disclosed under any circumstance.

7.1.4 Personal Identification Number (PIN) Authentication

Personal identification number (PIN) shall be encrypted adopting the method of cryptogram authentication, i.e., using the PIN entered by user to encrypt the random number generated by card, and sending the encrypted data into card and comparing with the encryption result of the same random number by PIN in card to verify whether PINs are consistent; for details, refer to description of Get Challenge and Verify PIN commands.

7.2 Secure Message Transport

The aim of secure message transport is to ensure the reliability and integrity of data and authentication of sender. Authentication of data integrity and sender will be realized by using MAC. Reliability of data will be guaranteed through encryption of data fields.

7.2.1 Secure Message Transport Format

Secure message transport format defined in this part complies with stipulations of ISO 7816-4. When the second nibble of CLA byte is equal to hexadecimal digit 4, it indicates that command data of the sender shall be transported adopting secure

message. FCI in card indicates whether data in data field of a command needs encryption transport and whether is shall be processed with encryption methods.

Table 7.1 Secure Message Transport Format Specification

b4	b3	b2	b1	Description
0	0	x	x	Secure message not required
0	1	x	x	Secure message required

7.2.2 Message Integrity and Authentication

MAC is generated by all elements using the command (including command header). Integrity of a command, including data element in command data field (if any) will be ensured through secure message transport.

7.2.2.1 Location of MAC

MAC is the last data element in command data field.

7.2.2.2 Length of MAC

In this part, length of MAC is defined to be 4 or 8 bytes.

7.2.2.3 Generation of MAC key

MAC session keys used in the process of secure information processing are generated according to the procedures of session keys generation as described in 7.3.4. Original key of MAC DEA key is used to generate MAC session key.

7.2.2.4 MAC Computation

Use single or triple DEA encryption method to generate MAC according to the following way:

Step 1: take 8 bytes hexadecimal number 0 as initial variable.

Step 2: concatenate the following data in order to form data block:

CLA, INS, P1, P2, Lc¹

Data including plain text or encrypted data in data field of command (if any).

Step 3: divide the data block into 8-byte data blocks, mark as D1, D2, D3, D4, and so on. The last data block could have 1-8 bytes.

Step 4: if the length of the last data block is 8 bytes, add hexadecimal number 80 00 00 00 00 0000 at the end and go to Step 5.

¹ Lc indicates the length of 4 bytes MAC data at the end of command data field, for example: APPLICATION BLOCK command shall generate a MAC, the input value of Lc for calculating MAC is 4-FE rather than 0, CLA includes representation of secure message ("X4").

If the length of the last data block is less than 8 bytes, then add hexadecimal number 80 at the end; if reaching the length of 8 bytes, then go to step 5; otherwise, add hexadecimal number 0 at the end until the length reaches 8 bytes.

Step 5: use MAC session key to encrypt such data blocks, with session key generated according to the method as described in 7.3.2.3. If secure message supports single length MAC DEA key, then use MAC session key to generate MAC as shown in the 0 below (according to different lengths of data block generated in Step 2, there may be more or less than 4 steps in computation)

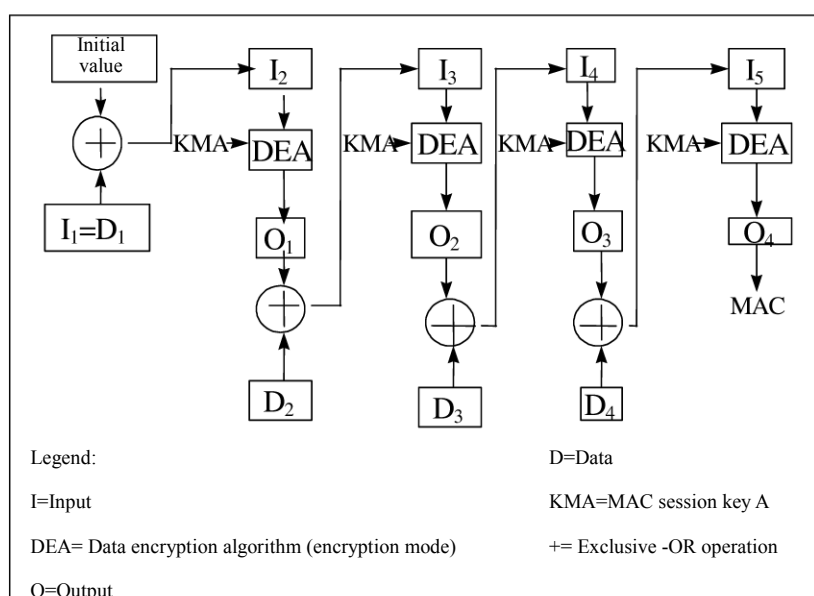


Figure 7.1 MAC Algorithm of Single Length DEA Key

If secure message supports double length MAC DEA key, then use MAC session key A and B to generate MAC as shown in the 0 below (according to different lengths of data block generated in Step 2, there may be more or less than 4 steps in computation)

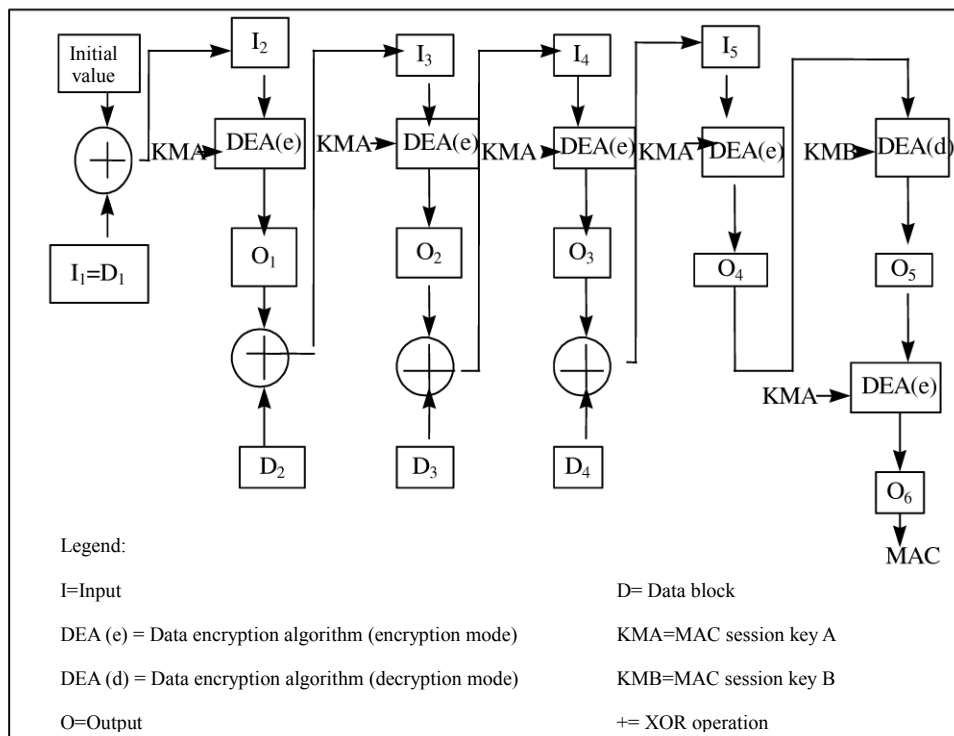


Figure 7.2 MAC algorithm of double length DEA Key

Step 6: finally get the 4 bytes long MAC obtained from left side of the computation result.

7.2.3 Data Reliability

In order to ensure the confidentiality of plain text data in command, data could be encrypted. All the data encryption techniques used shall be known by sender of the command and the application selected in the current card.

7.2.3.1 Computation of Data Encryption Key

For data used in secure message processing, encryption session key shall be generated according to the method as described in 7.3.4. The generation process of data encryption session key starts from data encryption DEA key in card.

7.2.3.2 Structure of Encrypted Data

When the plain text data required in command needs to be encrypted, it shall be first formatted as data blocks in the following form:

- *length of plain text data, excluding pad character (LD)*
- *plain text data*
- *pad character (according to requirements of 7.3.3.3)*

Then the entire data block needs to be encrypted using data encryption technique described in 7.3.3.3.

7.2.3.3 Data Encryption Computation

Data encryption technique is described as follows:

Step 1: use LD to represent the length of plain text data and add LD in front of plain text data to generate new data block.

Step 2: break data block generated in step 1 into 8-byte data blocks, mark as D1, D2, D3, D4, and so on. The length of the last data block may be less than 8 bytes.

Step 3: if the length of the last (only) data block is 8 bytes, go to Step 4; otherwise, add hexadecimal number 80 on the right. If the length reaches 8 bytes, go to Step 4; otherwise, add 1 byte hexadecimal number 0 on the right until the length reaches 8 bytes.

Step 4: each data block shall be encrypted adopting the data encryption method as described in 7.3.3.1.

If single length data encryption DEA key is adopted, encryption of data block is shown in the 0 below (use data encryption session key A to perform encryption)

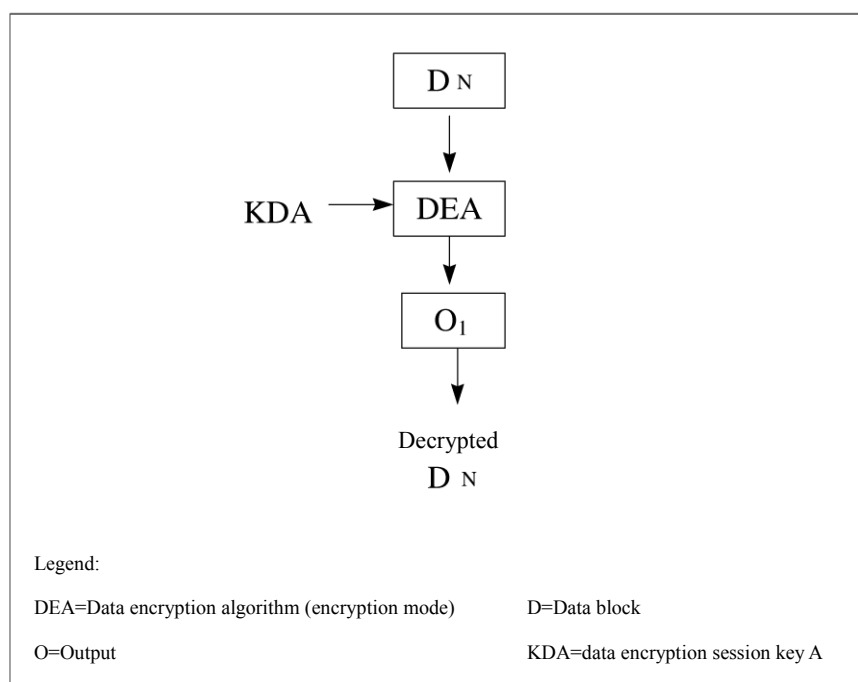


Figure 7.3 Data Encryption Using Single Length DEA Key

If double length data encryption DEA key is adopted, encryption of data block is shown in the 0 below (use data encryption session key A and B to perform encryption)

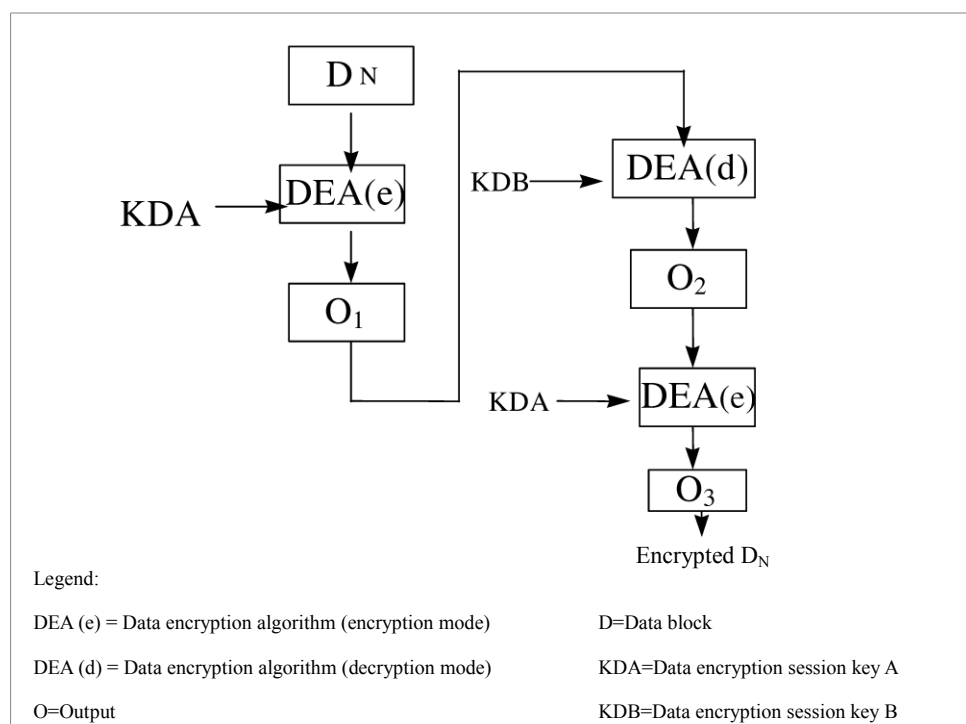


Figure 7.4 Data Encryption Using Double Length DEA Key

Step 5: after computation is completed, all encrypted data blocks shall be concatenated in the original order (encrypted D1, encrypted D2, and so on) and insert result data block into command data field.

7.2.3.4 Data Decryption Computation

After receiving command, card shall decrypt the encryption data contained in command. Data decryption technique is as follows:

Step 1: break data block in command data field into 8-byte data blocks, mark as D1, D2, D3, D4, and so on. Each data block shall be decrypted using the data encryption session key generated adopting the method as described in 7.3.3.1.

If single length data encryption DEA key is adopted, decryption of data block is shown in 0(use data encryption session key A to perform decryption)

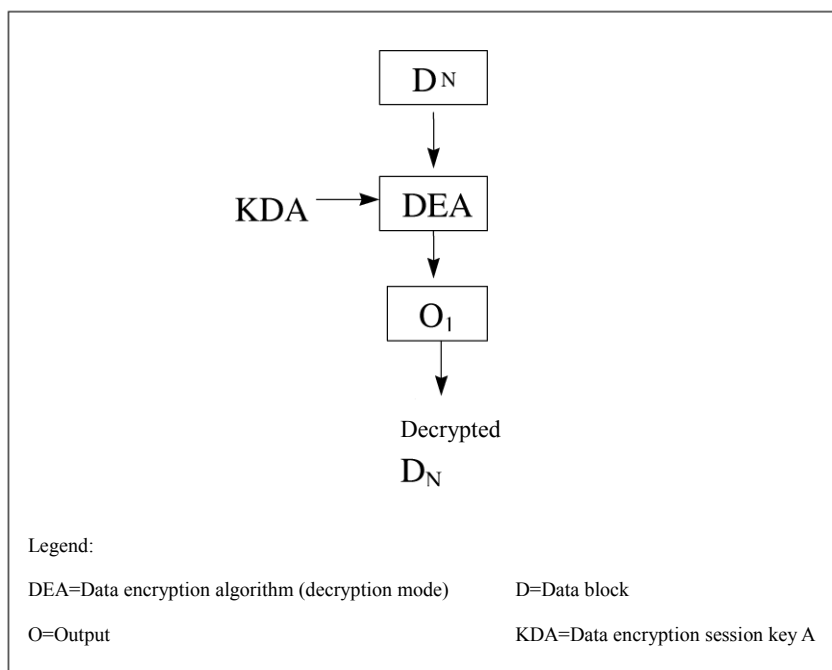


Figure 7.5 Data Decryption Using Single Length DEA Key

If double length data encryption DEA key is adopted, decryption of data block is shown in the 0 below (use data encryption session key A and B to perform decryption)

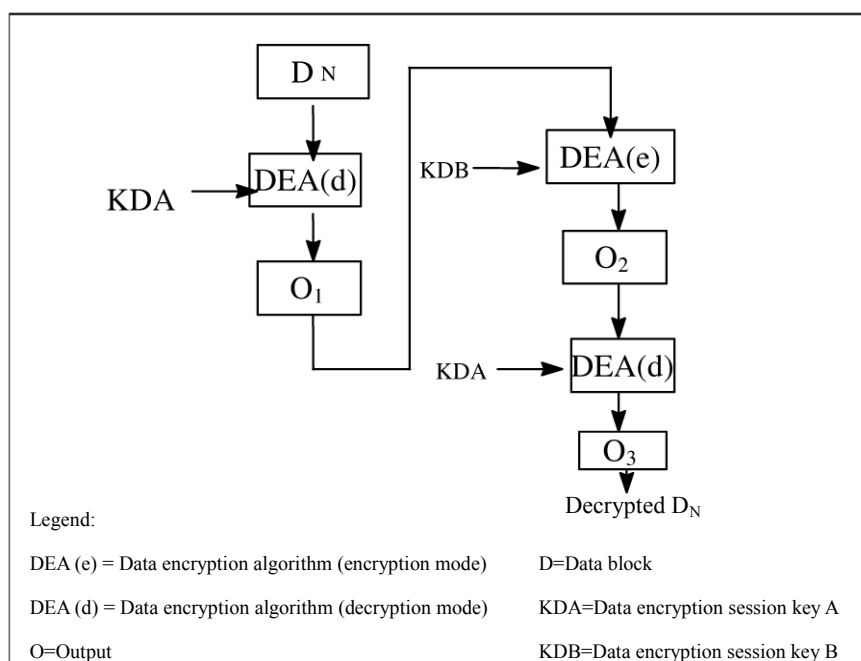


Figure 7.6 Data Decryption Using Double Length DEA Key

Step 2: after computation is completed, all decrypted data blocks shall be concatenated in the original order (encrypted D1, encrypted D2, and so on) Data block

consists of LD, plain text data and pad character (if added in the encryption process as described in 7.3.3.3)

Step 3: as LD represents the length of plain text data, it is used to recover plain text data.

7.2.4 Cases for Secure Message Transported Command

Four cases of commands are defined in *ISO/IEC 7816-4:2005*. This section briefly discusses the role of these cases on command APDU.

Case 1: In this case, no data is sent to ICC (Lc) and no data is returned from card (Le). Command without secure message transport requirements is as follows:

CLA	INS	P1	P2
-----	-----	----	----

Command with secure message transport requirements is as follows:

CLA	INS	P1	P2	Lc	MAC
-----	-----	----	----	----	-----

The second nibble of CLA being 4 indicates that secure message transport technique in case 2 is supported. Lc is the length of MAC.

Case 2: In this case, no data in command is sent to card but there is data returned from card. Command without secure message transport requirements is as follows:

CLA	INS	P1	P2	Lc
-----	-----	----	----	----

Command with secure message transport requirements is as follows:

CLA	INS	P1	P2	Lc	MAC	Le
-----	-----	----	----	----	-----	----

The second nibble of CLA being 4 indicates that secure message transport technique in case 2 is supported. Lc is the length of MAC.

Case 3: In this case, there is data in command sent to card but there is no data returned from card. Command without secure message transport requirements is as follows:

CLA	INS	P1	P2	Lc	Command data
-----	-----	----	----	----	--------------

Command with secure message transport requirements is as follows:

CLA	INS	P1	P2	Lc	Command data	MAC
-----	-----	----	----	----	--------------	-----

The second nibble of CLA being 4 indicates that secure message transport technique in case 2 is supported. Lc is the length of command data plus MAC.

Case 4: In this case, there is data in command sent to card and there is also data returned from card. Command without secure message transport requirements is as follows:

CLA	INS	P1	P2	Lc	Command data	Le
-----	-----	----	----	----	--------------	----

Command with secure message transport requirements is as follows:

CLA	INS	P1	P2	Lc	Command data	MAC	Le
-----	-----	----	----	----	--------------	-----	----

The second nibble of CLA being 4 indicates that secure message transport technique in case 2 is supported. Lc is the length of command data plus MAC.

7.3 Approved Encryption Algorithm

This part mainly describes digital certificate application card approved encryption algorithms and it's not mandatory that card should support all algorithms described in this part.

7.3.1 Symmetric Algorithm (DES)

Secure message allow the use of 64 bit block encryption algorithm, which is defined in ISO 8731-1, ISO 8732 and ISO/IEC 10116. Single DES and 3-DES encryption versions defined as follows could both be used in encryption operation and MAC mechanism as described in the third section.

3-DES encryption refers to the use of double length (16 byte) key $K = (K_L || K_R)$ to encrypt 8 byte plain text data block into cipher text data block, as follows:

$$Y = \text{DES}(K_L)[\text{DES}^{-1}(K_R)[\text{DES}(K_L)[X]]]$$

Decryption method as follows:

$$X = \text{DES}^{-1}(K_L)[\text{DES}(K_R)[\text{DES}^{-1}(K_L)[Y]]]$$

7.3.2 Asymmetric Algorithm (RSA)

RSA algorithm is used to perform static and dynamic data verification and digital signature. The index of public key can be odd number or even number.

The length of digital signature generated by algorithm is equal to the size of modulus used. The maximum limit of modulus is shown below:

Table 7.2 Maximum Limit of Different Modules in Bytes

Description	Description
Issuer public key modulus of digital certificate application	256 bytes
IC card public key modulus of digital certificate application	256 bytes

In the meantime, issuer public key modulus length of digital certificate application N_I and IC card public key modulus length of digital certificate application N_{IC} shall satisfy the following requirement: $N_{IC} < N_I$.

When selecting the length of public key modulus, the life cycle of keys and possibility of decryption in the life cycle shall be considered. The length range (upper and lower limits) of each key shall be stipulated in corresponding specific specification.

The index length of issuer's public key and index length of IC card public key shall be determined by digital certificate application issuer. Index could be predetermined fixed number such as 3 or 65537.

The key, signature and recovery function of RSA algorithm are described below. Odd and even indexes of public keys will be considered separately. In the meantime, minimum requirements for key generation process are also stipulated.

7.3.2.1 Odd Public Key Index

7.3.2.1.1 Key

Private Key S_K of RSA digital signature mechanism with odd public key index e includes two prime numbers p and q , with $p-1$ and $q-1$ being relatively prime numbers of e , whose relationship with private key index d is as follows:

$$ed \equiv 1 \pmod{(p-1)(q-1)}$$

Corresponding public key P_K includes public key modulus $n=pq$ and public key index e .

7.3.2.1.2 Signature Function

RSA signature function with odd public key index is defined as follows:

$$S = \text{Sign}(S_K)[X] = X^d \pmod{n}, \quad 0 < X < n,$$

X is the data to be signed and S is the corresponding digital signature.

7.3.2.1.3 Recovery Function

RSA recovery function with odd public key index is defined as follows:

$$X = \text{Recover}(P_K)[S] = S^e \pmod{n}$$

7.3.2.2 Generation of Keys

The major requirement for RSA key is to ensure modulus is a prime number, i.e., an integer that can't be decomposed by effective factorization algorithm with special purpose.

7.3.3 Secure Hash Algorithm (SHA-12)

This algorithm is standardized in FIPS 1801². Input any length information in SHA-1 to generate a 20 byte hash value.

7.3.4 Symmetric Algorithm (SM1)

Domestic grouping encryption algorithm

7.3.5 Asymmetric Algorithm (SM2)

Domestic asymmetric algorithm

7.3.6 Digest Algorithm (SM3)

Domestic digest algorithm Input any length information in SM3 to generate a 32 byte digest value.

² For SHA-1 standard, refer to ISO/IEC CD 10118-3.

8 Command

8.1 C-APDU Format

C-APDU is composed of 4 bytes mandatory header followed by a variable-length conditional body, see the chart below:

CLA	INS	P1	P2	Lc	Data	Le
←Mandatory header→				←Conditional body→		

Number of bytes of data sent in C-APDU shall be expressed with Lc (length of command data field)

Number of bytes of data expected to be returned in R-APDU shall be expressed with Le (expected data length) When Le exists and the value is 0, it indicates maximum number of bytes is required (256 bytes). When required by command message, Le is always set as 00.

Contents of C-APDU message are shown in the table below:

Code	Description	Length
CLA	Command type	1
INS	Command code	1
P1	Command parameter 1	1
P2	Command parameter 2	1
Lc	Number of bytes existing in command data field	0 or 1
Data	Data bit string sent by command(=Lc)	Variable
Le	Expected maximum number of data bytes in response data field	0 or 1

8.2 R-APDU Format

R-APDU format is composed of a variable-length conditional body and a two-byte mandatory end, see the chart below:

Data	SW1	SW2
←Conditional body→	←end→	

Contents of R-APDU message are shown in the table below:

Code	Description	Length
Data	Data bit string received in response(=Lr)	Variable-length
SW1	Command processing status	1
SW2	Command processing limit	1

When using T=1 protocol, for all Le='00' commands, status code SW1 SW2 = '90 00' or '61 La' indicate successful execution of command. Due to the requirement for readability, the two response codes only use '90 00' as reference in the article.

This section describes the following command - response APDU:

- CREATE FILE (create file)
- COMPUTE DIGITAL SIGNATURE (digital signature)
- COMPUTE HASH (HASH computation)
- ENCIPHER/DECIPHER (Encipher/decipher computation)
- VERIFY PIN (PIN verification)
- GET CHALLENGE (get the random number)
- GENERATE ASYMMETRIC KEY (generate public and private key pair)
- MANAGE SECURITY ENVIRONMENT (security environment management)
- PERFORM SECURITY OPERATION (security operation)
- READ BINARY (read binary file)
- READ RECORD (read record file)
- UPDATE BINARY (update binary file)
- UPDATE RECORD (update record file)
- VERIFY SIGNATURE (signature verification)
- WRITE PIN (load or update PIN)

8.3 Create File

8.3.1 Definition and Scope

Create command is used to create a data file in digital certificate application; either binary file or record file can be created. Create File command allocates space needed by files, which shall be indicated in the command data field.

For variable-length record files, this command only indicates the total size of space needed, rather than the length of each record. Specific length of each record shall be determined by Update Record command used for the first time.

After files are created, default data shall be filled with 0x00.

8.3.2 Command Message

Code	Value
CLA	'80'
INS	'E2'
P1	'00'
P2	'00'~'04'
Lc	'07'
Data	
Le	N/A

Interpretation of P1 bytes is as follows:

P1='00' indicates creating binary file;

P1='01' indicates creating fixed length record file;

P1='02' indicates creating cyclic record file;

P1='03' indicates creating variable-length record file;

P1='04' indicates creating special variable-length record file, used to create private key data file or public key data file.

8.3.3 Command Message Data Field

Command message data field includes the following contents:

Byte	Data element	Length
1-2	File identifier (FID)	2
3	Read authorization ('00' indicates free plain text writing, '01' indicates PIN verification needed)	1
4	Write authorization (the same as above)	1
5	Short file identifier (1-31)	1

Byte	Data element	Length
6-7	File size (binary or variable-length record file: size of 2-byte file) Fixed length file or cyclic record file: 1 byte record number+ 1 byte record length	2

8.3.4 Response Message Data Field

Response message data field does not exist.

8.3.5 Response Message Status Code

Status code for successful execution of the command is '9000'.

Warning status code possibly sent by IC card is as follows:

Status code	Meaning
'6581'	Memory Failed
'6700'	Length error
'6982'	Security conditions not satisfied
'6985'	Use conditions not satisfied
'6A80'	Incorrect data structure
'6A81'	Function not supported
'6A84'	Not enough space

8.4 Compute Digital Signature

8.4.1 Definition and Scope

Compute Digital Signature command is the subcommand of Perform Security Operation command. This command is used to compute signature for HASH value, which is computed from Compute HASH command. In other words, before executing Compute Digital Signature card, there must be a valid HASH value stored in card.

Before executing the command, Manage Security Environment command must be successfully executed to designate the private key ID and Alg-ID (designated padding method) of digital signature computation.

8.4.2 Command Message

Code	Value
CLA	'00'

Code	Value
INS	'2A'
P1	'9E'
P2	'9A'
Lc	N/A
Data	N/A
Le	'00'/' Length of signature data

8.4.3 Command Message Data Field

Command message data field does not exist

8.4.4 Response Message Data Field

Response message data field returns signature data.

8.4.5 Response Message Status Code

Status code for successful execution of the command is '9000'.

Warning status code possibly sent by IC card is as follows:

Status code	Meaning
'6581'	Memory Failed
'6700'	Length error
'6982'	Security conditions not satisfied
'6985'	Use conditions not satisfied
'6A80'	Incorrect data structure
'6A81'	Function not supported
'6A84'	Not enough space
'6E01'	Invalid command sequence
'6E02'	No security environment or invalid security environment.

8.5 Compute HASH (HASH Computation)

8.5.1 Definition and Scope

Compute HASH command is to compute the data entered by command into a HASH value using designated HASH algorithm.

The HASH value computed through one or several Compute HASH commands is stored in EEPROM for use by subsequent Compute Digital Signature command or Verify Signature command.

Data to be computed is divided into multiple 64-byte data blocks and the last data block could be less than 64 bytes. Each data block shall be sent into card through a Compute HASH command.

8.5.2 Command Message

Code	Value
CLA	'00'/'01' '00' indicates the current command is the last HASH computation command; '01' indicates the current command is not the last HASH computation command;
INS	'2A'
P1	'90'
P2	'80'/'A0' '80' indicates HASH computation shall be completed by card. 'A0' indicates HASH computation shall be completed by card and terminal jointly
Lc	Length of data to be computed
Data	Data to be computed
Le	N/A or HASH value

8.5.3 Command Message Data Field

Command message data field includes data to be computed

When terminal only performs HASH computation for part of the data to be computed

DATA = '91' || '1C' || middle HASH value || Counter || '81' || L || remaining data to be computed;

Where, middle HASH value and Counter shall be computed by terminal; Counter has 8 bytes, indicating the number of bytes of data entered already computed.

If terminal does not participate in HASH computation, '91' || '1C' || middle HASH value || Counter will be omitted and HASH value will be directly computed by the card.

When terminal calculates HASH for all data pending calculation:

DATA = '91' || '14' || final HASH value (use SHA-1, RIPEMD-160 algorithm to calculate, computed by terminal); or DATA = '91' || '20' || final HASH value (use SM3 algorithm to calculate, computed by terminal).

8.5.4 Response Message Data Field

If the current command is not the last HASH computation command, then response message does not exist.

If the current command is the last HASH computation command, then response message shall be the HASH value computed.

8.5.5 Response Message Status Code

Status code for successful execution of the command is '9000'.

Warning status code possibly sent by IC card is as follows:

Status code	Meaning
'6581'	Memory Failed
'6700'	Length error
'6982'	Security conditions not satisfied
'6985'	Use conditions not satisfied
'6A80'	Incorrect data structure
'6A81'	Function not supported
'6A84'	Not enough space
'6E01'	Invalid command sequence
'6E02'	No security environment or invalid security environment.

8.6 Encipher/Decipher

8.6.1 Definition and Scope

Encipher/decipher command is the subcommand of Perform Security Operation command, which is used to encipher/decipher data.

Before execution of the command, Manage Security Environment command must be successfully executed to designate public key for encryption or private key for decryption, and designated keys must have corresponding encryption/ decryption function.

When command is used for encryption mode, P1='86', P2='80';

When command is used for decryption mode, P1='80', P2='86';

8.6.2 Command Message

Code	Value
CLA	'00'
INS	'2A'
P1	'80'/'86'
P2	'80'/'86'
Lc	Length of data to be enciphered/deciphered
Data	Data to be enciphered/deciphered
Le	'00'

8.6.3 Command Message Data Field

Command message data field includes data to be enciphered/deciphered

8.6.4 Response Message Data Field

Response message data field includes PI (padding mark, '00') and cryptogram data when command is in encryption mode;

Response message data field includes deciphered plain text data when command is in decryption mode;

8.6.5 Response Message Status Code

Status code for successful execution of the command is '9000'.

Warning status code possibly sent by IC card is as follows:

Status code	Meaning
'6581'	Memory Failed
'6700'	Length error
'6982'	Security conditions not satisfied
'6985'	Use conditions not satisfied
'6A80'	Incorrect data structure
'6A81'	Function not supported
'6A84'	Not enough space
'6E01'	Invalid command sequence

Status code	Meaning
'6E02'	No security environment or invalid security environment.

8.7 Verify PIN (PIN Verification)

8.7.1 Definition and Scope

Verify PIN command requires application in card to verify the PIN entered.

Before execution of the command, Get Challenge command shall be executed first to get an 8-byte random number.

8.7.2 Command Message

Code	Value
CLA	'00'
INS	'82'
P1	'00'/'01' '00' indicates using DES algorithm to compute authentication data; '01' indicates using SM1 algorithm to compute authentication data;
P2	'00'
Lc	'08'
Data	Authentication data
Le	N/A

8.7.3 Command Message Data Field

Command message data field includes authentication data. Authentication data is the cryptogram result computed from the random number returned by Get Challenge command to PIN entered by user using the P1 designated encryption algorithm. Length of PIN shall be limited to 4-8 bytes; if PIN is less than 8 bytes, it shall be padded to 8 bytes by adding 'FF' from the right side.

8.7.4 Response Message Data Field

Response message data field does not exist.

8.7.5 Response Message Status Code

Status code for successful execution of the command is '9000'.

Warning status code possibly sent by IC card is as follows:

Status code	Meaning
'6581'	Memory Failed
'6700'	Length error
'6982'	Security conditions not satisfied
'6985'	Use conditions not satisfied
'6A80'	Incorrect data structure
'6A81'	Function not supported
'63CX'	Error in PIN verification, X number of attempts remaining
'6988'	Number of errors in PIN verification exceeds limit, PIN blocked

8.8 Get Challenge (Get Random Number)

8.8.1 Definition and Scope

Get Challenge command is used to request a random number used in secure process from card.

The random number can only be used in the next command, which shall be immediately expired regardless of whether the next command uses it or not.

8.8.2 Command Message

Code	Value
CLA	'00'
INS	'84'
P1	'00'
P2	'00'
Lc	N/A
Data	N/A
Le	'04'/'08'

8.8.3 Command Message Data Field

Command message data field does not exist.

8.8.4 Response Message Data Field

Response message data field includes random number, with the length of 4 or 8 bytes.

8.8.5 Response Message Status Code

Status code for successful execution of the command is '9000'.

Warning status code possibly sent by IC card is as follows:

Status code	Meaning
'6581'	Memory Failed
'6700'	Length error
'6982'	Security conditions not satisfied
'6985'	Use conditions not satisfied
'6A80'	Incorrect data structure
'6A81'	Function not supported

8.9 Generate Asymmetric Key (Generate Public and Private Key Pair)

8.9.1 Definition and Scope

Generate Asymmetric Key command is used to generate a complete asymmetric public and private key pair; for RSA algorithm, the key shall include the following key components: prime number p and q , $1/e \bmod (p-1)$, $1/e \bmod (q-1)$, $1/q \bmod p$; for SM2 algorithm, the key shall include the key components stipulated by algorithm. Key components will be stored in corresponding key files and specific key record shall be determined by KID designated by P2. Public key value of key pair generated shall be returned in response message.

Length of key generated shall be designated by command data field, which shall be within the range of 64-256 bytes and be an integral multiple of 8.

Before loading private key and public key using this command, it must be ensured that the corresponding private key header and public key header have been loaded to the respective key files via Update Record command; and the KID of public key and that of private key shall be consistent.

8.9.2 Command Message

Code	Value
CLA	'00'

Code	Value
INS	'47'
P1	'00'/'01' '00' indicates generating RSA public and private key pair, with public key index of '010001' '01' indicates generating RSA public and private key pair, with public key index of '03' '10' indicates generating SM2 public and private key pair
P2	KID
Lc	'02'
Data	2 byte key length (in bit)
Le	'00'

8.9.3 Command Message Data Field

Command message data field includes 2 byte key length, used to designate the length of asymmetric public and private key pair generated by the command.

8.9.4 Response Message Data Field

Response message data includes RSA public key modulus generated. Its structure is as follows:

Mark	Length(byte)	Value	STYLE
'6E'	Public key length	Public key value	M

8.9.5 Response Message Status Code

Status code for successful execution of the command is '9000'.

Warning status code possibly sent by IC card is as follows:

Status code	Meaning
'6581'	Memory Failed
'6700'	Length error
'6982'	Security conditions not satisfied
'6985'	Use conditions not satisfied
'6A80'	Incorrect data structure

Status code	Meaning
'6A81'	Function not supported
'6A84'	Not enough space

8.10 Manage Security Environment (Security Environment Management)

8.10.1 Definition and Scope

Manage Security Environment command is used to designate corresponding data parameters for all the security operation commands, such as designating public/private key involved in signature and encryption/decryption and algorithm for digital signature.

If command data field designates a private key, card needs to verify the following information first:

- *Whether there is RSA/SM2 private key designated by SKID in corresponding key file;*
- *Whether the key is allowed to be used by Compute Signature or Encipher/Decipher command;*

If command data field designates a public key, card needs to verify the following information first:

- *Whether there is public key designated by PKID in corresponding key file;*
- *Whether the key is allowed to be used by Verify Signature command and Encipher/Decipher command;*

In the process of security management, Manage Security Environment command can be used only once.

After this command designates public key/private key, subsequent related security management commands will determine whether to use RSA or SM2 domestic algorithm according to the algorithm type designated by algorithm identification byte in key header.

8.10.2 Command Message

Code	Value
CLA	'00'
INS	'33'
P1	

Code	Value
P2	
Lc	Length of subsequent data
Data	TLV data object
Le	N/A

P1 P2 could have the following combinations:

P1	P2	Command corresponding with TLV data object
'42'	'A6'	Verify Signature command
'42'	'A8'	Encipher/Decipher command (encipher mode)
'82'	'A6'	Compute Signature command
'82'	'A8'	Encipher/Decipher command (decipher mode)

8.10.3 Command Message Data Field

Command data field consists of one or more TLV structures according to corresponding subsequent command.

The TLV structure is showed in the table below:

Type	T	L	V
Private key KID	'80'	'01'	SKID
Public key KID	'81'	'01'	PKID
Digest Algorithm ID	'82'	'01'	Alg-ID

Alg-ID codes corresponding with command related with Compute Signature command and meanings are shown in the table below:

Alg-ID	HASH algorithm	Padding mode	ASN.1-OID
'11'	SHA-1	According to DIN V66291-1 designated padding mode	
'12'	SHA-1	According to PKCS#1 block type 01 mode	{1 3 14 3 2 26} (OIW)
'21'	RIPEMD-160	According to DIN V66291-1 designated padding mode	

Alg-ID	HASH algorithm	Padding mode	ASN.1-OID
'22'	RIPEMD-160	According to PKCS#1 block type 01 mode	{1 3 36 3 2 1} (TeleTrust)
'32'	MD-5	According to PKCS#1 block type 01 mode	{1 2 840 113549 2 5} (RSADSI)
'42'	SM3		

Alg-ID = '11' is the standard HASH algorithm and padding mode, if there is no designated Alg-ID, standard HASH algorithm and padding mode will be used.

Alg-ID codes and meanings corresponding to Encipher/Decipher command are shown in the table below:

Alg-ID	HASH algorithm	Padding mode
'02'	SHA-1	According to PKCS#1 block type 02 mode
'03'	SHA-1	No padding
'04'	SM3	

8.10.4 Response Message Data Field

Response message data field does not exist.

8.10.5 Response Message Status Code

Status code for successful execution of the command is '9000'.

Warning status code possibly sent by IC card is as follows:

Status code	Meaning
'6581'	Memory Failed
'6700'	Length error
'6982'	Security conditions not satisfied
'6985'	Use conditions not satisfied
'6A80'	Incorrect data structure
'6A81'	Function not supported

Status code	Meaning
'6A84'	Not enough space
'6E01'	Invalid command sequence
'6E02'	No security environment or invalid security environment.

8.11 Perform Security Operation (Security Operation)

Perform Security Operation command includes the following subcommands:

- *Compute Digital Signature command*
- *Compute HASH command*
- *Encipher/Decipher command*
- *Verify Certification command*
- *Verify Signature command*

INS byte of all subcommands shall be '2A'.

8.12 Read Binary (Read Binary File)

8.12.1 Definition and Scope

Read Binary command is used to read contents (or part of contents) of binary file.

8.12.2 Command Message

Code	Value
CLA	'00'
INS	'B0'
P1	See codes in the below table
P2	Offset address of the first byte read from file
Lc	N/A
Data	N/A
Le	'00'

P1 parameter codes are as follows:

b8	b7	b6	b5	b4	b3	b2	b1	Meaning
1	0	0						RFU
			X	X	X	X	X	SFI

8.12.3 Command Message Data Field

Command message data field does not exist.

8.12.4 Response Message Data Field

When Le value is 0, as long as the maximum length of file is between 256 (short length) to 65536 (extended length), all bytes will be read.

8.12.5 Response Message Status Code

Status code for successful execution of the command is '9000'.

Warning status code possibly sent by IC card is as follows:

Status code	Meaning
'6581'	Memory Failed
'6700'	Length error
'6982'	Security conditions not satisfied
'6985'	Use conditions not satisfied
'6A80'	Incorrect data structure
'6A81'	Function not supported
'6A84'	Not enough space

8.13 Read Record (Read Record File)

8.13.1 Definition and Scope

Read Record command is used to read contents of record file

8.13.2 Command Message

Code	Value
CLA	'00'
INS	'B2'
P1	Number of records

Code	Value
P2	Refer to the table below
Lc	N/A or 5 bytes
Data	N/A
Le	N/A

P2 parameter codes are as follows:

b8	b7	b6	b5	b4	b3	b2	b1	Meaning
X	X	X	X	X				SFI
					1	0	0	Record No. given in PI

8.13.3 Command Message Data Field

Command message data field does not exist.

8.13.4 Response Message Data Field

Response message data field does not exist.

8.13.5 Response Message Status Code

Status code for successful execution of the command is '9000'.

Warning status code possibly sent by IC card is as follows:

Status code	Meaning
'6581'	Memory Failed
'6700'	Length error
'6982'	Security conditions not satisfied
'6985'	Use conditions not satisfied
'6A80'	Incorrect data structure
'6A81'	Function not supported
'6A84'	Not enough space

8.14 Update Binary (Update Binary File)

8.14.1 Definition and Scope

Update Binary command uses data in command data field to modify data already existing in EF file.

8.14.2 Command Message

Code	Value
CLA	'00'
INS	'D6'
P1	See codes in the below table
P2	Offset address of the first byte to be modified
Lc	Length of subsequent data
Data	Data used in modification
Le	N/A

P1 parameter codes are as follows:

b8	b7	b6	b5	b4	b3	b2	b1	Meaning
1	0	0						RFU
			X	X	X	X	X	SFI

8.14.3 Command Message Data Field

Command message data field includes data used in modification.

8.14.4 Response Message Data Field

Response message data field does not exist.

8.14.5 Response Message Status Code

Status code for successful execution of the command is '9000'.

Warning status code possibly sent by IC card is as follows:

Status code	Meaning
'6581'	Memory Failed
'6700'	Length error

Status code	Meaning
'6982'	Security conditions not satisfied
'6985'	Use conditions not satisfied
'6A80'	Incorrect data structure
'6A81'	Function not supported
'6A84'	Not enough space

8.15 Update Record (Update Record File)

8.15.1 Definition and Scope

Update Record command uses data given in command data field to modify designated record.

8.15.2 Command Message

Code	Value
CLA	'00'
INS	'DC'
P1	'00' indicates the current record No./other value indicates designated record No.
P2	Refer to the table below
Lc	Length of subsequent data
Data	Update new record of original record
Le	N/A

P2 parameter codes are as follows:

b8	b7	b6	b5	b4	b3	b2	b1	Meaning
X	X	X	X	X				SFI
					0	0	0	First record
					0	0	1	Last record
					0	1	0	Next record
					0	1	1	Previous record

b8	b7	b6	b5	b4	b3	b2	b1	Meaning
					1	0	0	Record No. given in PI
Other values								RFU

8.15.3 Command Message Data Field

Command message data field includes updating new record of original record

8.15.4 Response Message Data Field

Response message data field does not exist.

8.15.5 Response Message Status Code

Status code for successful execution of the command is '9000'.

Warning status code possibly sent by IC card is as follows:

Status code	Meaning
'6581'	Memory Failed
'6700'	Length error
'6982'	Security conditions not satisfied
'6985'	Use conditions not satisfied
'6A80'	Incorrect data structure
'6A81'	Function not supported
'6A84'	Not enough space

8.16 Verify Signature (Signature Verification)

8.16.1 Definition and Scope

Verify Signature command is the subcommand of Perform Security Operation command. This command is used by card to verify signature entered by terminal. Before performing signature verification, the following conditions must be satisfied:

- There is HASH value stored in card;
- Length of signature falls within the range of 64 bytes to 256 bytes;
- There exists corresponding public key;

Before executing the command, Manage Security Environment command must be successfully executed to designate public key ID and Alg-ID for signature verification;

8.16.2 Command Message

Code	Value
CLA	'00'
INS	'2A'
P1	'00'
P2	'A8'
Lc	Length of data to be verified
Data	Signature data to be verified
Le	N/A

8.16.3 Command Message Data Field

Command message data field includes signature data to be verified.

8.16.4 Response Message Data Field

Response message data field does not exist.

8.16.5 Response Message Status Code

Status code for successful execution of the command is '9000'.

Warning status code possibly sent by IC card is as follows:

Status code	Meaning
'6581'	Memory Failed
'6700'	Length error
'6982'	Security conditions not satisfied
'6985'	Use conditions not satisfied
'6A80'	Incorrect data structure
'6A81'	Function not supported
'6A84'	Not enough space
'6E01'	Invalid command sequence

Status code	Meaning
'6E02'	No security environment or invalid security environment.

8.17 Write PIN (Load or Update PIN)

8.17.1 Definition and Scope

Write PIN command is used to load or update PIN.

When the command is used to update PIN, command data field shall be derived by old PIN value performing symmetric encryption operation on new PIN value.

8.17.2 Command Message

Code	Value
CLA	'80'
INS	'F4'
P1	'00'/'01' '00' indicates loading PIN; '01' indicates updating already existing PIN
P2	'00'/'01' When P1='00', P2='00' indicates using DES algorithm 8 byte PIN; P2='01' indicates using SM1 algorithm 16 byte PIN; When P1='01', P2='00' indicates using DES algorithm for encryption computation; P2='01' indicates using SM1 algorithm for encryption computation;
Lc	'0A'/'12'/'10'/'20'
Data	PIN value/encrypted PIN information
Le	N/A

8.17.3 Command Message Data Field

Command message data field includes PIN value.

When P1 = '00', load new PIN; format of command message data field is as follows:

Upper limit of PIN attempts	Initial number of PIN Try	PIN plain text value (8/16 bytes)
'XX'	'XX'	When actual PIN length is less than 8/16 bytes, fill with 'FF' on the right

If P1 = '01', update existing PIN value adopting DES algorithm, format of command message data field is as follows:

PIN cryptogram value (16 bytes)
Use old PIN value to perform encryption protection on data (8 byte old PIN value, 8 byte new PIN value), generate 16 byte cryptogram; when length of new PIN or old PIN is less than 8 bytes, pad 'FF' on the right; when card receives command, verify old PIN value and update PIN value after successful verification.

If P1 = '01', update existing PIN value adopting SM1 algorithm; format of command message data field is as follows:

PIN cryptogram value (32 bytes)
Use old PIN value to perform encryption protection on data (16 byte old PIN value, 16 byte new PIN value), generate 32 byte cipher text; when length of new PIN or old PIN is less than 16 bytes, pad 'FF' on the right; when card receives command, verify old PIN value and update PIN value after successful verification.

8.17.4 Response Message Data Field

Response message data field does not exist.

8.17.5 Response Message Status Code

Status code for successful execution of the command is '9000'.

Warning status code possibly sent by IC card is as follows:

Status code	Meaning
'6581'	Memory Failed
'6700'	Length error
'6982'	Security conditions not satisfied
'6985'	Use conditions not satisfied
'6A80'	Incorrect data structure
'6A81'	Function not supported

Status code	Meaning
'6A84'	Not enough space

Appendix A Basic Data File (EF)

Table A.1 Card information data file

File identifier (SFI)		'12' (decimal)
Document type		Transparent
File size		30
Document Access control	Read = Open	Rewrite = PIN verification needed
Byte	Data element	Length
1	Issuer application version	1
2-11	Application serial No.	10
12-13	Card Manufacturer Information	2
14-15	Supporting algorithm information	2
16-23	Issuer identifier	8
24-27	Last application update date	4
28-30	Last application update time	3

Table A.2 Public key data file

File identifier (SFI)		'10' (decimal)
Document type		Special linear variable-length
File size		
Document Access control	Read = CHV	Rewrite = PIN PIN verification
Byte	Data element	Length
1	Public key algorithm identifier	1
2	Key attributes	1
3	ACV ('00' indicates using the public key freely; '01' indicates PIN verification needed to use the public key, other value invalid)	1

File identifier (SFI)		'10' (decimal)
4	Public Key ID (PKID)	1
5	Public key parameter information	1
6-7	Key length	2
8-X	Public key value	X-8

Codes of public key algorithm identifier bytes are as follows:

B1	B2	B3	B4	B5	B6	B7	B8	Description
0	0	0	0					
				X				Key format
				0				From high byte to low byte (normal order)
				1				From low byte to high byte (reverse order)
						X	X	Asymmetric algorithm
						0	1	RSA algorithm
						1	0	SM2 algorithm

Codes of key attribute bytes are as follows:

B1	B2	B3	B4	B5	B6	B7	B8	Description
0		0	0	0				RFU
	X							Whether the public key is allowed to be covered
	0							No
	1							Yes
					X			Whether it's allowed to be used in Verify Signature command
					0			No
					1			Yes
						X		RFU

B1	B2	B3	B4	B5	B6	B7	B8	Description
							X	Whether it's allowed to be used in Decipher/Encipher command
							0	No
							1	Yes

Codes of key ID are as follows:

B1	B2	B3	B4	B5	B6	B7	B8	Description
0	0							RFU
		X	X	X	X	X	X	Value

Table A.3 Private key data file

File identifier (SFI)		'11' (decimal)
Document type		Special linear variable-length
File size		
Document Access control		Rewrite = PIN PIN verification
Read = Prohibited		
Byte	Data element	Length
1	Private key algorithm identifier	1
2	Key attributes	1
3	ACV ('00' indicates using the private key freely; '01' indicates PIN verification needed to use the private key, other value invalid)	1
4	Private key ID(SKID)	1
5	Private key parameter information	1
6-7	Key length	2
8-X	Private key information list (SIL)	n
8-X+n	Private key value	m

Except for private key parameter information bytes, key attribute bytes and private key information list, codes of other bytes in private key data file are the same with codes of corresponding bytes in public key data file.

Private key parameter information is equal to RFU; private key attribute byte codes are as follows:

B1	B2	B3	B4	B5	B6	B7	B8	Description
0		0	0	0		0		RFU
	X							Whether the private key is allowed to be covered
	0							No
	1							Yes
					X			Whether it's allowed to be used in Compute Digital Signature command
					0			No
					1			Yes
							X	Whether it's allowed to be used in Decipher/Encipher command
							0	No
							1	Yes

Composition format of private key information list (SIL) and corresponding key components in private key file record are as follows:

Private key information list							Private key		
SIL length	I1	L1	I2	L2	In	Ln	Private key component 1	Private key component 2	Private key component n
1 byte	[SIL length] byte						L1	L2	L3

SIL includes length of private key components and sequence and other information, with the codes of In byte as follows:

B1	B2	B3	B4	B5	B6	B7	B8	Description
0	0	0	0					RFU

B1	B2	B3	B4	B5	B6	B7	B8	Description
				X	X	X	X	Type of private key components
				0	0	0	0	n RSA public key
				0	0	0	1	p RSACRT private key
				0	0	1	0	q RSACRT private key
				0	0	1	1	d RSACRT private key
				0	1	0	0	$d \bmod (p - 1)$ RSACRT private key
				0	1	0	1	$d \bmod (q - 1)$ RSACRT private key
				0	1	1	1	$1/q \bmod p$ RSACRT private key
				1	0	0	0	SM2 public key
				1	0	0	1	SM2 private key component 1
				1	0	1	0	SM2 private key component 2
				1	0	1	1	SM2 private key component 3
				1	1	0	0	SM2 private key component 4
				1	1	0	1	SM2 private key component 5

Table A.4 Certificate data file

File identifier (SFI)		'13' (decimal)
Document type		Transparent
File size		4096
Document Access control	Read = Open	Rewrite = PIN verification needed
Byte	Data element	Length
1-4096	Certificate content value	4096

Appendix B Loading of Asymmetric Key

B.1 Use Update Record Command To Load Private Key

Private key shall be written into private key data file by an Update Record command.

Usually, before key is used, COS must first verify if the length byte of the key is consistent with actual key length; if verification is successful, then the key can be used as designated by Manage Security Environment command.

The private key loading process is as shown in Chart B.1.

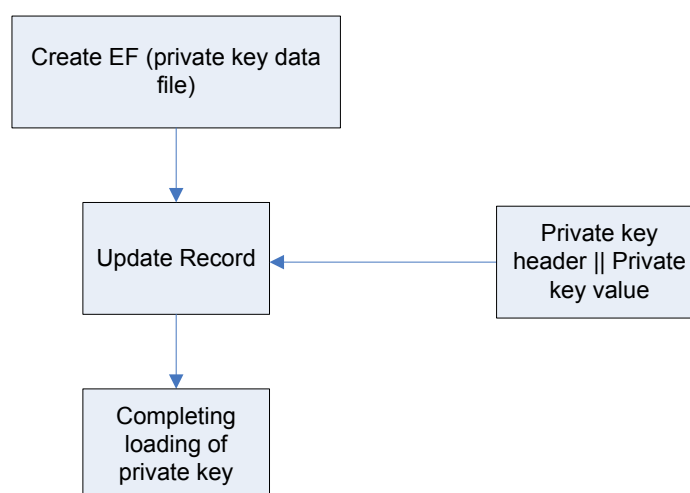


Figure B.1 Procedures of loading private key using Update Record command

Considering security factors, the method of loading private key externally is usually not adopted, instead, public and private key pair is generated in the card directly through Generate Asymmetric Key, with private key never out of the card, thus ensuring the confidentiality and security of private key.

B.2 Use Update Record Command To Load Public Key

Public key shall be written into public key data file by an Update Record command.

Usually, before key is used, COS must first verify if the length byte of the key is consistent with actual key length; if verification is successful, then the key can be used as designated by Manage Security Environment command.

The public key loading process is as shown in Chart B.2.

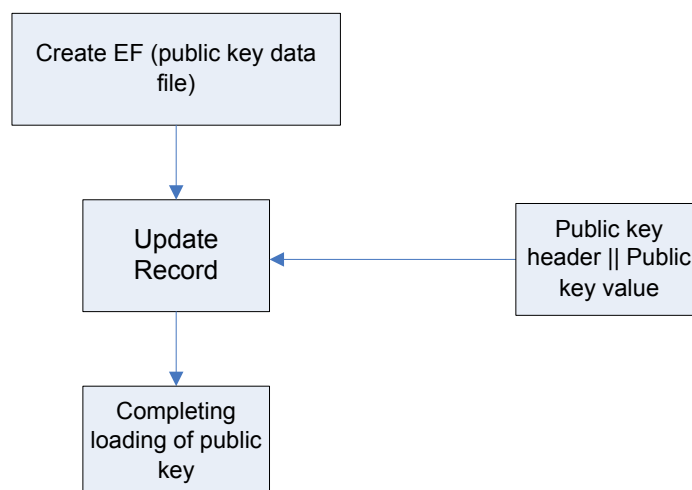


Figure B.2 Procedures of loading public key using Update Record command

B.3 Use Generate Asymmetric Key Command to Load (Generate) Public Key and Private Key Simultaneously

Before using Generate Asymmetric Key command to load public key and private key simultaneously, it must be guaranteed that private key head and public key head have been separately loaded into private key data file and public key data file by Update Record command. Meanwhile, private key SKID and public key PKID must be consistent. The loading process is as shown in Chart B.3.

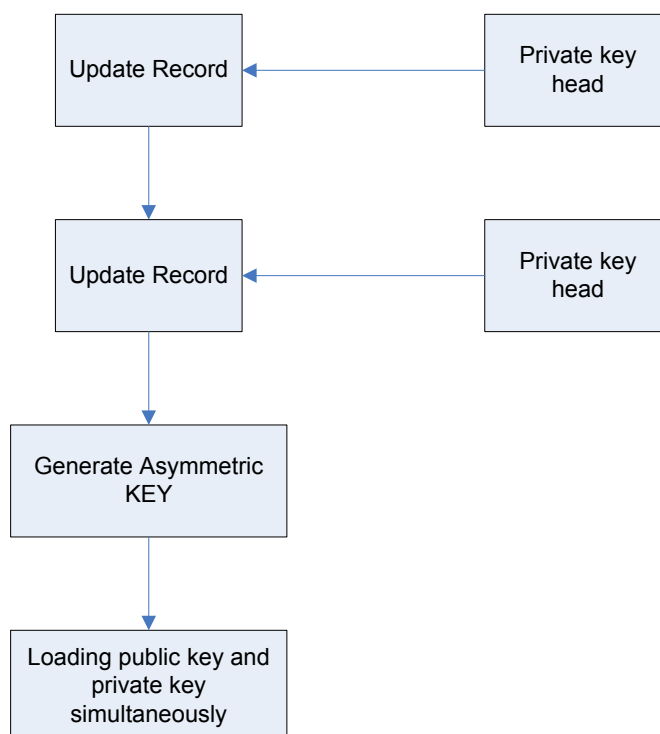


Figure B.3 Procedures of loading private key and public key simultaneously using Generate Asymmetric Key command

Appendix C Card Reader Terminal Configuration Recommendation

In order to ensure secure transaction, this part describes recommended requirements for card reader terminals of digital certificate application IC card, which are not mandatory. According to different security levels, type I and type II terminals shall have different hardware configuration requirements.

Table C.1 Card reader terminal configuration recommendation

Terminal hardware device	Type I	Type II
Display screen	Optional	Mandatory
IC card interface	Mandatory	Mandatory
Confirmation button	Mandatory	Mandatory
Cancel button	Mandatory	Mandatory
Digital keyboard	Optional	Mandatory
Page Up button	Optional	Optional
Page Down button	Optional	Optional
USB communication interface	Mandatory	Mandatory
Chinese character expanded character set	Optional	Optional